1 Muss ich wissen

Security Engineering und Systemgrenze

F5–8,16; T1:41–6:55,13:08–15:13

- **Security Engineering** baut Systeme, die trotz **malice, error and mischance** zuverlässig bleiben, und umfasst Entwurf, Implementierung, Tests sowie Anpassung an eine veränderte Umgebung.
- **System** bedeutet hier ausdrücklich Definition 6: Produkt und Hardware, Betriebssystem und Kommunikation, Anwendungen einschließlich Cloud, IT-Personal, interne Nutzer und Management sowie Kunden und externe Nutzer.
- **Interdisciplinary expertise** verbindet Business Processes, Software Engineering und Testing mit Kryptografie, Computer Security, Hardware-Schutz, Economics, Psychology, Organisation und Law.
- **Adversarial Thinking** untersucht frühere Angriffe, Zugangswege und Folgen, statt Security nur als Verhindern unerwünschter Ereignisse zu verstehen.
- **Typische Fehler** sind der Schutz falscher Assets, ungeeignete Schutzmaßnahmen und das Ignorieren menschlicher Komponenten oder der Usability.

Workflow: vier Schritte in dieser Reihenfolge

F10–14; T7:19–12:58

- **Threat Model**: feststellen, wer warum und wie angreifen könnte, einschließlich Insidern, Outsidern, Menschen und Malware.
- **Security Policy**: festlegen, welche Schutzeigenschaften und Regeln für die Geschäftsziele gelten sollen.
- **Implementation**: passende Schutzmechanismen auswählen und umsetzen.
- **Assurance**: begründetes Vertrauen schaffen und auch Dritten nachweisen, dass die Schutzziele erreicht sind, statt nur ein Compliance-Zertifikat vorzuweisen.

Subject, Person, Principal, Group und Role

F17–19; T15:18–19:44

- **Subject** ist in dieser Vorlesung eine natürliche Person in einer beliebigen Rolle, etwa Operator oder Victim.
- **Person** kann eine natürliche oder juristische Person sein, etwa ein Mensch oder eine Firma.
- **Principal** ist eine authentifizierbare Entität, die im Security System handelt, und kann auch eine Smartcard, ein Kommunikationskanal, eine Role oder ein Zusammenschluss sein.
- **Group** bezeichnet eine Menge von Principals, während eine **Role** eine Menge von Funktionen bezeichnet, die nacheinander verschiedene Personen übernehmen.
- **Abstraction Level** muss ausdrücklich genannt werden, weil Bobs Smartcard als Vertretung Bobs etwas anderes ist als Bob als Bediener von Alices Smartcard.

Identity sowie trusted versus trustworthy

F20–21; T19:44–22:08

- **Identity** ist hier eine Zuordnung zwischen Namen zweier Principals, die dieselbe Person oder dasselbe Gerät bezeichnen, und nicht bloß ein Name.
- **Trusted** heißt, dass der Ausfall einer Komponente die Security Policy verletzen kann, während **trustworthy** laut Kursdefinition heißt, dass sie nicht versagt.
- **Trusted but not trustworthy** ist beispielsweise ein Geheimnisträger, der entgegen seiner Verpflichtung geheime Informationen verkauft.

1 Muss ich wissen – Abgrenzungen

Secrecy, Privacy, Confidentiality und Anonymity

F22–23; T22:29–26:32

- **Secrecy** bezeichnet das Verhindern von Informationsweitergabe.
- **Privacy** ist die Fähigkeit und/oder das Recht, persönliche Informationen und den persönlichen Raum vor Eingriffen zu schützen.
- **Confidentiality / non-disclosure** ist die Verpflichtung, anvertraute Geheimnisse anderer Personen oder Organisationen zu schützen.
- **Patientendaten**: das Schutzrecht des Patienten gehört zu Privacy, die Geheimhaltungspflicht des Arztes zu Confidentiality.
- **Anonymity** verhindert die Zuordnung einer Handlung zu einer Person, weshalb geheime Nachrichteninhalte allein nicht genügen und verräterische Metadaten sowie IP-Adressen relevant bleiben.

Integrity, Authenticity, Availability und Security Failure

F24; T26:42–28:09

- **Integrity** sichert zu, dass Daten bei Speicherung oder Übertragung nicht verändert wurden.
- **Authenticity** bedeutet hier **Integrity + Freshness + Proof of Identity**, sodass ein echter Principal statt einer Wiederholung alter Nachrichten festgestellt wird.
- **Availability** bedeutet, dass autorisierte Nutzer bei Bedarf auf Daten und Netzwerkressourcen zugreifen können.
- **Security Failure** ist eine unerwünschte Verletzung der Security Policy eines Systems.

Weakness, Vulnerability, Exploit und Threat

F25–28; T28:24–35:19

- **Weakness** ist eine Bedingung in einer Software- oder Hardwarekomponente, die zur Entstehung von Vulnerabilities beitragen kann.
- **Vulnerability** ist eine Schwäche des Systems oder seiner Umgebung, die zusammen mit einer internen oder externen Threat zu einem Security Failure führen kann.
- **Exploit** ist eine Methode oder ein Stück Code, das eine Vulnerability ausnutzt.
- **Threat** ist eine Handlung oder ein Ereignis mit möglicher negativer Systemwirkung, während ein **Threat Actor** eine Entität ist, die eine Threat verursachen, ausführen, übertragen, unterstützen oder ausnutzen kann.
- **CWE** katalogisiert Weakness-Typen wie **CWE-125: Out-of-bounds Read**, während **CVE** konkrete Vulnerabilities wie **CVE-2014-0160: Heartbleed** in OpenSSL bezeichnet.

Policy, Target, Protection Profile und Hack

F25,29–30; T28:24–29:03,35:53–39:32

- **Security Policy (what)** ist eine knappe Schutzstrategie in Business Goals, etwa die Freigabe großer Banktransaktionen durch zwei Manager.
- **Security Target / Goal (how)** ist die detaillierte, produktspezifische Spezifikation der Schutzmittel und dient als Maßstab für die Implementation, ist aber noch nicht deren Umsetzung.
- **Protection Profile** beschreibt Anforderungen ausreichend geräteunabhängig, um verschiedene Produkte und Versionen vergleichend zu bewerten, und verbindet Policy und Target.
- **Protection** ist eine abstrakte Schutzeigenschaft wie Confidentiality oder Integrity.
- **Hack** ist nach der im Kurs verwendeten Definition etwas, das die Systemregeln erlauben, das die Designer aber weder vorgesehen noch gewollt haben.

2 Hinweise der Lehrperson

Was für den Minitest lernen? T1:15–1:41; ergänzend F76–84

- **Ausdrücklicher Hinweis im Transkript**: Alle heute behandelten Definitionen lernen, weil jede davon im Minitest vorkommen kann.
- **Erster Minitest**: Die Fragenfolien nennen den **23.10.2026** und kennzeichnen ihre Fragenliste ausdrücklich als **nicht vollständig**.
- **Schwerpunkt laut F84**: Definitionen und Fragen am Ende des Foliensatzes priorisieren, aber das gesamte Skript lernen.
- **Umfang laut F84**: fünf Minuten am Vorlesungsbeginn mit zwei bis drei Fragen, insbesondere Multiple Choice und Fill in Text.
- **Nicht dieses Mal laut F84**: Mathematical Computations, was keine generelle Befreiung von solchen Aufgaben für spätere Tests bedeutet.

Organisation: im Transkript sinngemäß gesagt T0:00–1:09,9:28,35:19–35:37,42:09–42:37

- **Bewertung**: Es gibt zwölf Minitest-Gelegenheiten und die neun besten zählen, während Final Project 25 und Poster/Presentation 30 Punkte bringen.
- **Anwesenheit**: Höchstens drei Termine fehlen und auf die Anwesenheitsliste achten, die während oder am Ende der Stunde herumgeht.
- **Themenwahl**: Ein Thema aus der Online-Liste auswählen und dort eintragen oder ein eigenes Wunschthema per E-Mail mit der Lehrperson absprechen.
- **Projektinformationen**: Details stehen in den Folien der vorherigen Einheit, während im Transkript keine konkrete Abgabefrist genannt wird.
- **Abgrenzung der Einheit**: Researchers und Tools sind für die nächste Einheit angekündigt, Hacktivism und Script Kiddies werden hier nicht behandelt und Security Policies/Targets folgen als Vertiefung.

Quellenkonflikte nicht als Gewissheit lernen F3,84; T0:00–1:09

- **Testmedium ungeklärt**: F3 sagt „PEN + PAPER“, F84 dagegen „Moodle Quiz“, und die vorliegende Mitschrift löst diesen Widerspruch nicht auf.
- **Ersatzprüfung laut F3**: Bei mehr als drei Fehlterminen oder weniger als 20 Minitest-Punkten ist eine Final Exam vorgesehen, wobei dies keine Aussage über eine gesicherte Bestehensgrenze ist.

3 Gut zu wissen

Threat Modeling ist eine Priorisierungsentscheidung F8–9,32–34; T5:23–7:19,40:08–41:10

- **Assets** sind die schützenswerten Güter, deren Schutzbedarf zuerst geklärt werden muss.
- **Incentives und Capabilities** bestimmen, welche Gegner wahrscheinlich sind und welche Maßnahmen im konkreten Systemkontext passen.
- **Budget und Funktionalität** begrenzen den Schutz, weil nicht alle denkbaren Angriffe bei vertretbaren Kosten ausgeschlossen werden können.
- **Policy, Mechanism, Assurance und Incentives** beeinflussen sich gegenseitig, weshalb auch Schulung und passende Anreize der Betreiber zum Schutz gehören.

3 Gut zu wissen – State Actors

Five Eyes: Zugang zu Infrastruktur und Daten

F36–47; T43:05–1:01:00

- **Five Eyes / FVEY** sind USA, UK, Canada, Australia und New Zealand, deren **Platform Advantage** unter anderem aus gemeinsam nutzbarer Kommunikationsinfrastruktur entlang historischer Kabelrouten entsteht.
- **PRISM** steht im Kurs für Serverzugriff beziehungsweise **downstream collection**, während **TEMPORA** großflächigen Glasfaserzugriff beziehungsweise **upstream collection** bezeichnet.
- **XKEYSCORE** ist eine verteilte Suchmaschine über gesammelte Datenbestände, etwa für die Suche nach Kommunikation mit bestimmten Merkmalen.
- **Google-Rechenzentren**: Der im Kurs gezeigte historische Fall illustriert, dass SSL zum Frontend keinen Schutz für damals unverschlüsselte interne Datenverbindungen garantierte.
- **Operation Socialist** bezeichnet den im Kurs beschriebenen GCHQ-Angriff auf Belgacom und Roaming-Infrastruktur, während **Crypto Wars** Versuche zur Schwächung starker Kryptografie und Standards illustrieren.

China: gezielte Angriffe und eigener Platform Advantage

F48–53; T1:01:16–1:11:47

- **Dalai Lama Hack (2008)** wird im Kurs als Spear-Phishing mit anschließend kompromittiertem Mailserver und schädlichen PDF-Anhängen der tibetischen Exilregierung beschrieben.
- **Google Hack (2009)** sollte laut Fallstudie über die Infrastruktur für behördliche Datenzugriffe feststellen, welche chinesischen Geheimdienstmitarbeiter den US-Behörden bereits bekannt waren.
- **OPM Hack (2015)** betraf die Datenbank mit sensiblen Angaben aus Security-Clearance-Verfahren und damit auch Informationen über mögliche Erpressbarkeit.
- **Belt and Road**, Telekommunikationsausbau, Plattformen und AI dienen laut Vorlesung der strategischen Schaffung eines eigenen Infrastruktur- und Plattformvorteils.

Iran, North Korea und Russia: Fälle richtig zuordnen

F54–60; T1:11:47–1:23:10

- **Ohne vergleichbaren Platform Advantage** hebt der Kurs für diese Staaten insbesondere Spear-Phishing, Hacking und Information Warfare hervor.
- **Stuxnet** war ein Angriff **gegen Iran**, im Kurs USA und Israel zugeschrieben, bei dem ein Worm unter anderem über USB-Verbreitung Siemens-PLCs und damit Zentrifugenparameter manipulierte.
- **Sony Hack (2014)** wird North Korea zugeschrieben und als Reaktion auf *The Interview* mit Veröffentlichung interner Daten und E-Mails beschrieben.
- **Ukraine Power Grid (2015)** verbindet in der Vorlesung Stromabschaltungen mit einem gleichzeitigen DoS auf Callcenter, wodurch auch Störungsmeldungen erschwert wurden.
- **Russische Operationen** umfassen in den Fallbeispielen NotPetya, den **SolarWinds Supply-Chain Attack (2020)** und Einflussoperationen mit Datenleaks und Troll Farms.

3 Gut zu wissen – Motive und Ökosysteme

Intelligence Doctrine: fünf Elemente F61; T1:23:10–1:23:27

- **Collect**: Mehr und bessere Informationen als der Gegner sammeln.
- **Exploit**: Informationen zur Verbesserung der eigenen Position nutzen.
- **Undermine**: Moral, Institutionen und Allianzen des Gegners untergraben.
- **Disable**: Fähigkeiten des Gegners durch Sabotage ausschalten.
- **Preposition**: Eigene Mittel vorsorglich für einen möglichen Konflikt positionieren.

Crooks: Geld als Incentive F62–64; T1:23:27–1:24:45

- **Crooks** verfolgen vor allem finanziellen Gewinn, etwa durch Fraud, Scams oder Cryptocurrency Theft, statt primär einen staatlichen Intelligence Contest zu gewinnen.
- **Cybercrime Ecosystem** bedeutet Arbeitsteilung zwischen Bulk Attackers, Targeted Attackers, Tool- und Malware-Anbietern sowie Cashout Gangs.
- **Cashout Services / Money Mules** bewegen erbeutetes Geld über Konten und erschweren damit dessen Rückverfolgung.

Ransomware: ergänzender Inhalt desselben Foliensatzes F63–66; nicht in der Mitschrift ausgeführt

- **Ransomware** verschlüsselt laut Folien Opferdaten zur Lösegelderpressung und entwickelte sich von Massenangriffen auf private PCs zu groß angelegten Angriffen auf Unternehmen und Institutionen.
- **Cryptocurrencies** erleichtern laut Folien schwer rückverfolgbare Lösegeldzahlungen, und Ransomware wird als Wachstumsbereich seit 2020 genannt.

The Swamp: Abuse statt Profit F67–71; in der Mitschrift nur als Kategorie genannt

- **Abuse Incentives** stehen bei The Swamp im Vordergrund, etwa bei Hate Campaigns, Missbrauch in Beziehungen und School-/Workplace Bullying.
- **Weitere Folienbeispiele** sind Terrorism Recruitment und Child Sexual Abuse Material, nicht nur monetär motivierte Kriminalität.

Social Media und AI: zusätzliche Folien, keine Mitschrift-Aussage F72–75,82–83

- **Content Moderation** steht zwischen staatlichem Druck, hohen Filterkosten und Plattformentscheidungen, während Like/Share-Dynamiken schädliche Inhalte und öffentliche Beschämung verstärken können.
- **Gegenmaßnahmen** sind laut Folien teils technisch, teils politisch und teils eine Frage sozialer Normen.
- **AI-Agents: Tool or Actor?** wird als offene Frage nach Moral Agency und menschlicher Absicht diskutiert, wobei Freedom und Epistemic Competence als Bedingungen moralischer Verantwortung genannt werden.
- **Accountability** wird durch komplizierte Lieferketten und verteilte Verantwortlichkeiten erschwert, weshalb die Folien AI nicht einfach eindeutig als eigenständigen Täter einordnen.

4 Selbsttest – zehn kurze Fragen

Auswahl im Stil von F77–83; Antworten entsprechen den Definitionen dieses Kurses.

1. Was ist Security Engineering?

Systeme trotz **malice, error and mischance** zuverlässig halten, einschließlich Entwurf, Implementation, Tests und Anpassung an Veränderungen.

2. Welche vier Schritte hat der Workflow?

Threat Model → Security Policy → Implementation → Assurance: Gegner analysieren, Schutzziele festlegen, Mechanismen umsetzen und Zielerreichung auch Dritten nachweisen.

3. Wie unterscheiden sich Subject, Person und Principal?

Subject: natürliche Person; **Person**: natürliche oder juristische Person; **Principal**: authentifizierbare, im Security System handelnde Entität, auch ein Gerät oder eine Role.

4. Was bedeutet trusted, was trustworthy?

Trusted: Der Ausfall kann die Policy brechen; **trustworthy**: Die Komponente versagt laut Kursdefinition nicht.

5. Wie unterscheiden sich Privacy, Confidentiality und Anonymity?

Privacy: persönliches Schutzrecht beziehungsweise Schutzfähigkeit; **Confidentiality**: Geheimhaltungspflicht gegenüber anderen; **Anonymity**: keine Zuordnung einer Handlung zu einer Person.

6. Welche drei Teile umfasst Authenticity hier?

Integrity + Freshness + Proof of Identity: Die Daten sind unverändert und frisch, und der nachgewiesene Principal ist echt statt nur durch eine wiederholte alte Nachricht vorgetäuscht.

7. Weakness, Vulnerability, Exploit: welche Unterschiede?

Weakness: potenziell problematische Bedingung; **Vulnerability**: Schwäche, die mit einer Threat zum Security Failure führen kann; **Exploit**: Methode oder Code zur Ausnutzung.

8. Wie unterscheiden sich Policy, Target und Protection Profile?

Policy: Schutzziel in Business Goals; **Target**: produktspezifische Spezifikation der Mittel; **Protection Profile**: geräteunabhängig genug für vergleichende Produktbewertungen.

9. Wer sind die Five Eyes und was ist PRISM?

USA, UK, Canada, Australia, New Zealand; **PRISM** bezeichnet im Kurs Serverzugriff als downstream collection und ist von TEMPORAs upstream collection an Glasfasern zu unterscheiden.

10. Welche Motive unterscheiden States, Crooks und The Swamp?

States: Informations- und Machtvorteile sowie Sabotage und Konfliktvorsorge; **Crooks**: finanzieller Gewinn; **The Swamp**: Abuse, etwa Belästigung und Hasskampagnen.